

Relatório de Auditoria de Segurança — Orbia

Revisão estática de cinco superfícies de risco

28/08/2026

5 achados	4 alta	1 media	0 segredos confirmados
--------------	-----------	------------	---------------------------

Escopo: codigo fonte, preload, renderer, handlers IPC, services, testes, configuracoes, artefatos textuais de build e historico Git alcancavel no checkout em 28/08/2026. O worktree ja possuia alteracoes do usuario; elas foram preservadas e nao foram editadas.

Metodologia: deteccao da stack; mapeamento Main -> IPC -> preload -> renderer; leitura de todos os 254 registros ipcMain.handle/on em 18 modulos; rastreamento de caminhos e credenciais; busca de sinks XSS; revisao das protecoes e testes existentes.

Conclusao executiva

Foram confirmados cinco achados condicionais, concentrados na fronteira de confianca do renderer com o processo Main. Nao foi confirmado segredo exposto nem sink XSS executavel. O protocolo media://, as capabilities de importacao e o armazenamento seguro de credenciais sao protecoes reais, mas alguns endpoints legados contornam essa arquitetura.

1. Stack detectada e limites de aplicabilidade

Dimensao	Evidencia no projeto	Impacto na auditoria
Linguagem/runtime	TypeScript; Electron 39; processo Main Nodejs; preload isolado; renderer React 19 com Vite/electron-vite.	Privilegios importantes atravessam IPC, nao HTTP.
Persistencia	better-sqlite3 com SQL parametrizado; banco de configuracao e library.db por vault; WAL e foreign_keys ON.	Nao ha ORM/query builder. O limite de dados e o vault ativo, nao um tenant.
Auth/tenant	Nenhum login, sessao de usuario, organizationId, tenantId ou RLS foi encontrado. Perfis locais sao preferencias, nao identidade/autorizacao.	Banco sem tranca e IDOR classico: N/A por ausencia de fronteira multiusuario.
Frontend/bridge	BrowserWindow com contextIsolation=true e nodeIntegration=false; window.api expoe os handlers IPC ao renderer.	A autorizacao efetiva precisa existir no Main; controles de UI nao bastam.
Deploy	electron-builder.yml. Nao foram encontrados Dockerfile, CI, Helm, charts ou Terraform.	Nao ha superficie de segredo nesses mecanismos no checkout auditado.
AI	Providers local/cloud via fetch, credenciais em safeStorage, roteamento por privacyMode e allowlist.	O contrato opcional de dataTypes e relevante para F-01.

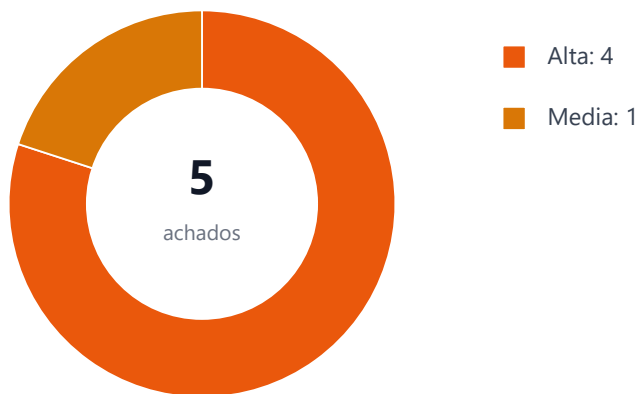
Status por categoria solicitada

Categoria	Status	Resultado verificado
1. Banco sem tranca	FORÇA	N/A como isolamento de tenant: nao existe auth/tenant/RLS. O banco ativo e por vault. SQL parametrizado, FK e WAL estao presentes.
2. Permissao definida no navegador	ALTA	Aplicavel. Os cinco achados exploram argumentos, caminhos ou classificacoes que chegam do renderer ao Main.
3. IDOR	FORÇA	N/A como IDOR entre usuarios: nao ha identidade/ownership. Ha mutacoes por IDs no vault ativo; isso e tratado em F-03 como falha de trust boundary IPC.
4. Chaves expostas	FORÇA	Nenhuma exposicao confirmada em source/config, .env, deploy, historico ou artefatos textuais. Fixtures e simbolos de apiKey foram distinguidos de credenciais reais.
5. Inputs sem tratamento / XSS	FORÇA	Nenhum sink perigoso confirmado. Nao ha dangerouslySetInnerHTML/innerHTML/eval/DOMParser; texto usa escaping React e links externos passam por HTTP/HTTPS.

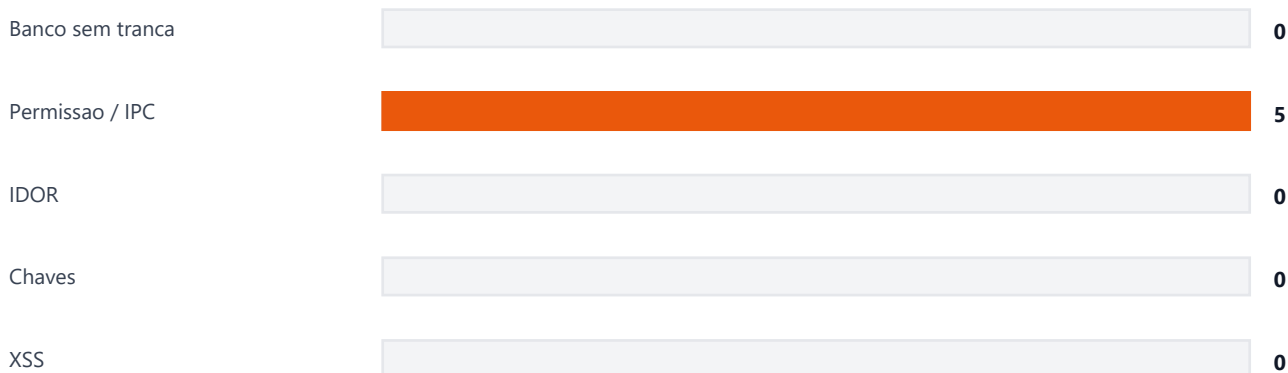
2. Resumo executivo

Os achados exigem um renderer comprometido, uma pagina nao confiavel navegando na janela ou uso de uma API exposta fora do fluxo normal. Isso e uma condicao de explorabilidade, nao uma afirmacao de que a UI normal dispara cada caminho sem acao do usuario.

Distribuicao por severidade



Distribuicao por categoria



Leituras prioritarias

- P1: fechar a fronteira Main/renderer para operacoes de filesystem e paths (F-02, F-03, F-04, F-05).
- P1: tornar classificacao e consentimento obrigatorios para qualquer envio cloud (F-01).
- P2: remover ou migrar endpoints legados para capabilities e sessoes Main-owned.
- P2: adicionar testes negativos de caminhos arbitrarios e chamadas IPC fora do fluxo da UI.

3. Pontos fortes e fragilidades

Protecoes confirmadas

- Electron usa contextIsolation=true e nodeIntegration=false; o preload expoe uma API tipada em vez de Node ao renderer.
- media:// valida protocolo, caminho absoluto, extensao, registro exato e arquivo regular; arquivo nao registrado retorna 403 antes do streaming.
- ImportSourceCapabilityRegistry usa token opaco, TTL de cinco minutos, tipo esperado e consumo one-shot; o fluxo novo de importacao exige sessao Main-owned.
- SQLite usa SQL parametrizado, WAL, foreign_keys ON e conexao do vault ativo como escopo operacional.
- Credenciais AI sao criptografadas por safeStorage e basic_text/unknown sao recusados; snapshots nao carregam o valor do segredo.
- React renderiza texto de documentos e linhas de codigo com escaping; nao foram encontrados sinks de HTML bruto ou avaliacao dinamica.
- Backup revalida entradas do arquivo e possui verificacoes contra path traversal; essa area nao produziu achado confirmado.

Fragilidades confirmadas

- O Main nao valida sender/origem nos handlers IPC; nao ha will-navigate guard e o bridge e amplo. Isso e a condicao comum dos achados, embora os cinco achados abaixo sejam os itens contabilizados.
- A arquitetura segura de importacao coexiste com endpoints legados que aceitam paths/propostas do renderer.
- Planos e flags de mutacao sao tratados como aprovados por terem vindo da UI, sem revalidacao de escopo no Main.
- O contrato generico de AI permite omitir a classificacao que a politica de privacidade usa como gatilho.
- A categoria de link importavel conflita com a semantica segura de abrir um caminho pelo aplicativo padrao do sistema.

4. Achados detalhados

Severidade	Arquivo:linha	Descricao
ALTA	src/main/services/ai/ai-routing.service.ts:60-72 src/main/ipc/ai.ipc.ts:162-208 src/main/services/ai/ai-core.service.ts:269-272 src/main/services/ai/ai-provider.ts:217-235 src/preload/index.ts:325-338 test/ai-core.test.ts:247-262	O caminho IPC de baixo nivel aceita mensagens ou entradas sem dataTypes. A protecao de nuvem so exige consentimento e allowlist quando dataTypes existe e nao esta vazia.
ALTA	src/preload/index.ts:7-15 src/main/ipc/vault.ipc.ts:92-99 src/main/services/vault.service.ts:216-222	O handler valida apenas que path e uma string nao vazia. Quando deleteFiles e true, o service remove recursivamente o caminho recebido sem confirmar que ele e um vault registrado ou selecionado pelo Main.
ALTA	src/main/ipc/courses.ipc.ts:812-824 src/main/services/database.service.ts:4502-4524 src/main/ipc/courses.ipc.ts:897-907 src/main/services/reorganizer.service.ts:209-234 src/types/course.ts:20-27,84-90	Operacoes destrutivas usam IDs sem uma identidade de caller e a reorganizacao aceita uma lista de mutacoes enviada pelo renderer. O service resolve diretamente sourcePath existente e move para destinationPath sem validar pertencimento ao curso ou ao vault.
MEDIA	src/main/ipc/settings.ipc.ts:74-82 src/main/utis/file-utis.ts:88-95 src/main/utis/file-utis.ts:158-166 src/preload/index.ts:396-400	A allowlist de extensoes e usada como unica barreira antes de shell.openPath. Ela inclui .lnk, .url, .html, .htm e .webloc; no Windows, abrir um .lnk pelo shell pode executar o alvo do atalho.
ALTA	src/main/ipc/courses.ipc.ts:671-685 src/main/ipc/courses.ipc.ts:695-719 src/main/services/course-import.service.ts:622-655,685-728 src/main/services/database.service.ts:126-147 src/main/protocol.ts:162-186,295-317 src/renderer/src/components/import/ImportWizard.tsx:322-366,459-485 src/main/ipc/courses.ipc.ts:863-877 src/main/services/organization/organization-plan.service.ts:198-234	O fluxo novo usa capabilities e sessoes Main-owned, mas o fluxo multi-curso ainda escaneia folderPath livre e import-batch persiste proposal.rootPath, lesson.filePath e resource.filePath sem verificar que vieram do scan autorizado.

F-01 - Classificacao de dados e consentimento sao opcionais no chat e embedding

Severidade: **ALTA** Categoria: Permissao no navegador / privacidade AI

O caminho IPC de baixo nivel aceita mensagens ou entradas sem dataTypes. A protecao de nuvem so exige consentimento e allowlist quando dataTypes existe e nao esta vazia.

Evidencia verificada

Arquivo:linha	Trecho/interpretacao
src/main/services/ai/ai-routing.service.ts:60-72	A verificacao de consentimento e da allowlist roda somente quando request.dataTypes existe e possui itens.
src/main/ipc/ai.ipc.ts:162-208	parseChatInput e parseEmbeddingRequest tratam dataTypes e cloudConsent como campos opcionais.
src/main/services/ai/ai-core.service.ts:269-272	O Main encaminha a request para assertPrivacyAllows sem preencher a classificacao ausente.
src/main/services/ai/ai-provider.ts:217-235	O provider envia o request HTTP e o Bearer do credential quando a rota e cloud.
src/preload/index.ts:325-338	chat e embed sao expostos diretamente ao renderer.
test/ai-core.test.ts:247-262	O teste considera valido o caminho cloud em HYBRID com chat sem dataTypes.

Explorabilidade: Requer privacyMode HYBRID ou CLOUD_ALLOWED, uma rota/provedor cloud habilitado e chamada direta a window.api.ai.chat ou window.api.ai.embed sem dataTypes. Nessa combinacao, a entrada segue para o provedor cloud.

Impacto: Notas, transcrições ou outros dados locais podem sair para um provedor externo sem a confirmação e a classificação previstas pelo modelo de privacidade.

Proteções existentes: O padrão é LOCAL_ONLY, provedores cloud iniciam desabilitados e os fluxos grounded/chapter/notes passam classificação explícita. O defeito permanece no contrato IPC genérico e nos testes que aceitam chat cloud sem dataTypes.

Recomendação: Torne a classificação um requisito derivado no Main para qualquer operação cloud; rejeite dataTypes ausente quando a entrada vier de conteúdo local, exija cloudConsent e allowlist, e remova ou restrinja o caminho genérico do renderer.

F-02 - vault:delete aceita qualquer caminho para remoção recursiva

Severidade: **ALTA** Categoria: Permissão no navegador / filesystem

O handler valida apenas que path é uma string não vazia. Quando deleteFiles é true, o service remove recursivamente o caminho recebido sem confirmar que ele é um vault registrado ou selecionado pelo Main.

Evidência verificada

Arquivo:linha	Trecho/interpretação
src/preload/index.ts:7-15	O renderer recebe vault.delete(path, deleteFiles) no bridge.
src/main/ipc/vault.ipc.ts:92-99	O handler repassa o path recebido e Boolean(deleteFiles) sem validação de registro ou capability.
src/main/services/vault.service.ts:216-222	Depois de remover do registro, deleteFiles dispara fs.promises.rm(trimmedPath, { recursive: true, force: true }).

Explorabilidade: Com o bridge disponível para um renderer comprometido ou uma página carregada indevidamente na janela, basta invocar vault:delete com qualquer diretório ou arquivo existente e deleteFiles=true.

Impacto: Pode apagar recursivamente dados fora do vault, incluindo diretórios do usuário. A remoção é executada com fs.promises.rm(..., recursive: true, force: true).

Proteções existentes: O service fecha o banco se o caminho é o vault atual e remove a entrada do registro. A UI possui confirmação, mas isso não é uma autorização confiável no Main.

Recomendação: Aceite somente uma referência de vault emitida pelo Main ou um caminho canônico presente no registro; valide raiz, tipo de objeto, vault atual e uma confirmação/capability de uso único antes de qualquer rm recursivo.

F-03 - Mutações de arquivos confiam em IDs e caminhos controlados pelo renderer

Severidade: **ALTA** Categoria: Permissão no navegador / mutações físicas

Operações destrutivas usam IDs sem uma identidade de caller e a reorganização aceita uma lista de mutações enviada pelo renderer. O service resolve diretamente sourcePath existente e move para destinationPath sem validar pertencimento ao curso ou ao vault.

Evidência verificada

Arquivo:linha	Trecho/interpretação
src/main/ipc/courses.ipc.ts:812-824	delete-lesson aceita lessonId e a flag de exclusão diretamente do renderer.
src/main/services/database.service.ts:4502-4524	O service busca file_path por ID e executa fs.unlinkSync(lesson.filePath) antes de apagar a linha.
src/main/ipc/courses.ipc.ts:897-907	apply-reorganize-plan aceita mutations e courseId sem validar a origem do plano.
src/main/services/reorganizer.service.ts:209-234	resolveActualSourcePath aceita sourcePath existente e safeMoveFile usa mutation.destinationPath sem containment check.
src/types/course.ts:20-27,84-90	O modelo suporta local-ref e caminhos físicos absolutos, inclusive fora do vault.

Explorabilidade: Um renderer comprometido pode chamar `courses:delete-lesson` com um `lessonId` valido e `deleteFileFromDisk=true`, ou `courses:apply-reorganize-plan` com `sourcePath/destinationPath` arbitrarios. O caminho da reorganizacao nem exige `courseId` valido em runtime.

Impacto: Uma aula pode apagar o arquivo fisico referenciado, inclusive em curso local-ref externo. A reorganizacao pode mover/copiar e apagar a origem de um arquivo fora do curso, criando tambem destino controlado pelo atacante.

Protecoes existentes: A aplicacao registra operacoes em journal e a UI mostra preview/aprovacao. O curso e consultado para gerar o plano, mas a aplicacao nao verifica que o plano recebido e o plano gerado nem limita `source/destination` ao `rootPath`.

Recomendacao: Valide no Main a relacao ID -> curso ativo e a politica de `sourceType`; para reorganizacao, emita e consuma um plano/capability Main-only, recanonicalize cada origem/destino dentro do root permitido e separe remocao de registro de exclusao fisica.

F-04 - system:open-path pode entregar atalhos e HTML ao aplicativo padrao

Severidade: **MEDIA** Categoria: Permissao no navegador / abertura pelo SO

A allowlist de extensoes e usada como unica barreira antes de `shell.openPath`. Ela inclui `.lnk`, `.url`, `.html`, `.htm` e `.webloc`; no Windows, abrir um `.lnk` pelo shell pode executar o alvo do atalho.

Evidencia verificada

Arquivo:linha	Trecho/interpretacao
src/main/ipc/settings.ipc.ts:74-82	<code>open-path</code> valida string, extensao e <code>isFile</code> , e entao chama <code>shell.openPath(filePath)</code> .
src/main/utls/file-utls.ts:88-95	<code>LINK_EXTENSIONS</code> inclui <code>.url</code> , <code>.lnk</code> , <code>.html</code> , <code>.htm</code> e <code>.webloc</code> .
src/main/utls/file-utls.ts:158-166	<code>isImportableFile</code> considera <code>LINK_EXTENSIONS</code> como permitido.
src/preload/index.ts:396-400	<code>openPath</code> e exposto ao renderer como funcao que aceita path livre.

Explorabilidade: Requer acesso ao bridge por renderer comprometido e a existencia de um arquivo com uma extensao aceita. Um `.lnk` pode apontar para um comando local; `.url` pode abrir uma URL e HTML pode executar conteudo no navegador padrao.

Impacto: O impacto varia de execucao de comando via atalho a phishing/navegacao externa. O risco nao e eliminado pelo teste de `stat.isFile()`.

Protecoes existentes: `system:open-external` restringe URL a `http/https`, e a aplicacao limita extensoes. A propria funcao `openPath`, porem, nao exige origem nativa, caminho registrado ou capability e contradiz o comentario de que nao executa caminhos arbitrarios.

Recomendacao: Remova tipos de link do caminho generico, ou aceite apenas uma capability emitida por `dialog.showOpenDialog` para um alvo explicitamente escolhido. Se HTML precisar ser aberto, trate-o como conteudo nao confiavel e nao o entregue ao shell sem politica clara.

F-05 - Endpoints legados permitem envenenar o registro de midia com caminhos do renderer

Severidade: **ALTA** Categoria: Permissao no navegador / registro e leitura de arquivos

O fluxo novo usa capabilities e sessoes Main-owned, mas o fluxo multi-curso ainda escaneia `folderPath` livre e `import-batch` persiste `proposal.rootPath`, `lesson.filePath` e `resource.filePath` sem verificar que vieram do scan autorizado.

Evidencia verificada

Arquivo:linha	Trecho/interpretacao
src/main/ipc/courses.ipc.ts:671-685	<code>scan-multi-course-folder</code> aceita <code>folderPath</code> cru e escaneia o diretorio recebido.

Arquivo:linha	Trecho/interpretacao
src/main/ipc/courses.ipc.ts:695-719	import-batch valida apenas items nao vazio e passa proposal diretamente a buildCourseHierarchy/saveCourseWithHierarchy.
src/main/services/course-import.service.ts:622-655,685-728	buildCourseHierarchy copia rootPath, lesson.filePath, coverPath e resource.filePath para entidades persistidas.
src/main/services/database.service.ts:126-147	getRegisteredMediaPaths agrega os caminhos persistidos em courses, lessons e content_resources.
src/main/protocol.ts:162-186,295-317	O media:// authorizer permite caminho registrado exatamente e o handler faz o streaming apos a autorizacao.
src/renderer/src/components/import/ImportWizard.tsx:322-366,459-485	O fluxo de multiplos cursos ainda chama scan cru e depois importBatch.
src/main/ipc/courses.ipc.ts:863-877	convert-srt-to-vtt tambem le e retorna conteudo de um srtPath cru apos apenas validar extensao/existencia.
src/main/services/organization/organization-plan.service.ts:198-234	applyPlan aceita details.newFilePath do plano recebido e grava file_path sem revalidar escopo.

Explorabilidade: Um renderer comprometido pode fabricar uma proposta apontando para um PDF, video ou recurso privado fora do curso selecionado e chamar import-batch. O mesmo limite aparece no plano de organizacao e no conversor SRT, que aceitam caminhos crus.

Impacto: Os caminhos persistidos entram em getRegisteredMediaPaths. O protocolo media:// entao os trata como registrados e permite leitura/streaming do arquivo pela aplicacao, transformando uma entrada controlada pelo renderer em autorizacao persistente.

Protecoes existentes: O protocolo rejeita caminhos nao registrados e os testes cobrem essa negativa. A registry de capability de importacao e one-shot/TTL, mas nao protege os endpoints legados ainda expostos no preload e usados pelo ImportWizard.

Recomendacao: Remova os endpoints legados ou faça-os consumir somente sessoes/capabilities Main-owned. Revalide canonical path, existencia, extensao e pertencimento ao sourceRoot no commit; nunca copie caminhos fisicos de propostas do renderer para o banco.

5. Plano de correcoes priorizado

Prioridade	Acao	Achados
P1	Fechar mutacoes/leituras de filesystem: capabilities Main-only, containment canonico e bloqueio de shell para links.	F-02, F-03, F-04, F-05
P1	Tornar classificacao, consentimento e allowlist obrigatorios para chat/embed cloud.	F-01
P2	Remover caminhos crus legados e exigir sessao/capability em importacao, plano de organizacao e conversao SRT.	F-05
P2	Adicionar validacao centralizada de sender/origem e uma politica de navegacao da BrowserWindow.	Condicao comum
P3	Manter testes de regressao para media nao registrado, safeStorage, capability one-shot e escaping React; adicionar os casos negativos listados nos issues.	Todos

Sequencia sugerida

- 1. Introduzir uma camada Main-only de autorizacao/capabilities para caminhos e planos; migrar os endpoints que hoje recebem paths crus.
- 2. Corrigir a politica AI e seus contratos/testes antes de habilitar uso cloud em fluxos novos.
- 3. Aplicar allowlist segura para abertura pelo SO e revisar navegacao da BrowserWindow.
- 4. Rodar a suite completa, typecheck e build; revisar novamente o bundle e o historico em CI.

6. ISSUES PARA O GITHUB

Os blocos abaixo estao prontos para abertura como issues. Cada bloco agrupa apenas evidencias da mesma causa ou correcao e preserva as condicoes de explorabilidade.

```
--- ISSUE 1 ---
title: [Seguranca] Exige classificacao e consentimento antes de enviar dados a provedores cloud
labels: security, severity:high
problem: O caminho IPC de baixo nivel aceita mensagens ou entradas sem dataTypes. A protecao de nuvem so exige consentimento e allowlist quando dataTypes existe e nao esta vazia.
exploitability: Requer privacyMode HYBRID ou CLOUD_ALLOWED, uma rota/provedor cloud habilitado e chamada direta a window.api.ai.chat ou window.api.ai.embed sem dataTypes. Nessa combinacao, a entrada segue para o provedor cloud.
evidence:
- src/main/services/ai/ai-routing.service.ts:60-72: A verificacao de consentimento e da allowlist roda somente quando request.dataTypes existe e possui itens.
- src/main/ipc/ai.ipc.ts:162-208: parseChatInput e parseEmbeddingRequest tratam dataTypes e cloudConsent como campos opcionais.
- src/main/services/ai/ai-core.service.ts:269-272: O Main encaminha a request para assertPrivacyAllows sem preencher a classificacao ausente.
- src/main/services/ai/ai-provider.ts:217-235: O provider envia o request HTTP e o Bearer do credential quando a rota e cloud.
- src/preload/index.ts:325-338: chat e embed sao expostos diretamente ao renderer.
- test/ai-core.test.ts:247-262: O teste considera valido o caminho cloud em HYBRID com chat sem dataTypes.
impact: Notas, transcricoes ou outros dados locais podem sair para um provedor externo sem a confirmacao e a classificacao previstas pelo modelo de privacidade.
fix: Centralizar uma funcao Main-only que derive dataTypes do fluxo e recusar requests cloud sem classificacao, consentimento e allowlist compatveis. Ajustar o contrato IPC e os testes do chat/embed.
acceptance checklist:
[ ] Chat e embedding cloud rejeitam entradas sem classificacao de dados.
[ ] Consentimento e allowlist sao verificados para cada tipo de dado.
[ ] Existe teste negativo para omissao de dataTypes no caminho IPC generico.
[ ] Os fluxos locais continuam funcionando em LOCAL_ONLY.
--- FIM ISSUE 1 ---
```

```
--- ISSUE 2 ---
title: [Seguranca] Restringe exclusao de vault a caminhos registrados e confirmados pelo Main
labels: security, severity:high
problem: O handler valida apenas que path e uma string nao vazia. Quando deleteFiles e true, o service remove recursivamente o caminho recebido sem confirmar que ele e um vault registrado ou selecionado pelo Main.
exploitability: Com o bridge disponivel para um renderer comprometido ou uma pagina carregada indevidamente na janela, basta invocar vault:delete com qualquer diretorio ou arquivo existente e deleteFiles=true.
evidence:
- src/preload/index.ts:7-15: O renderer recebe vault.delete(path, deleteFiles) no bridge.
- src/main/ipc/vault.ipc.ts:92-99: O handler repassa o path recebido e Boolean(deleteFiles) sem validacao de registro ou capability.
- src/main/services/vault.service.ts:216-222: Depois de remover do registro, deleteFiles dispara fs.promises.rm(trimmedPath, { recursive: true, force: true }).
impact: Pode apagar recursivamente dados fora do vault, incluindo diretorios do usuario. A remocao e executada com fs.promises.rm(..., recursive: true, force: true).
fix: Substituir path livre por uma capability de vault emitida pelo Main, normalizar/canonizar o alvo e recusar qualquer alvo fora de um vault registrado e validado. Manter a confirmacao de UI como camada adicional.
acceptance checklist:
[ ] Caminho nao registrado nunca chega a fs.promises.rm.
[ ] A capability expira e e de uso unico.
[ ] Arquivos fora do vault e o proprio diretorio-raiz protegido sao recusados.
[ ] Ha teste de regressao para path arbitrario com deleteFiles=true.
--- FIM ISSUE 2 ---
```

```
--- ISSUE 3 ---
title: [Seguranca] Valida escopo e proveniencia nas mutacoes fisicas de cursos
labels: security, severity:high
problem: Operacoes destrutivas usam IDs sem uma identidade de caller e a reorganizacao aceita uma lista de mutacoes enviada pelo renderer. O service resolve diretamente sourcePath existente e move para destinationPath sem validar pertencimento ao curso ou ao vault.
exploitability: Um renderer comprometido pode chamar courses:delete-lesson com um lessonId valido e deleteFileFromDisk=true, ou courses:apply-reorganize-plan com sourcePath/destinationPath arbitrarios. O caminho da reorganizacao nem exige courseId valido em runtime.
evidence:
- src/main/ipc/courses.ipc.ts:812-824: delete-lesson aceita lessonId e a flag de exclusao diretamente do renderer.
- src/main/services/database.service.ts:4502-4524: O service busca file_path por ID e executa fs.unlinkSync(lesson.filePath) antes de apagar a linha.
- src/main/ipc/courses.ipc.ts:897-907: apply-reorganize-plan aceita mutations e courseId sem validar a origem do plano.
- src/main/services/reorganizer.service.ts:209-234: resolveActualSourcePath aceita sourcePath existente e safeMoveFile usa mutation.destinationPath sem containment check.
- src/types/course.ts:20-27,84-90: O modelo suporta local-ref e caminhos fisicos absolutos, inclusive fora do vault.
```

impact: Uma aula pode apagar o arquivo fisico referenciado, inclusive em curso local-ref externo. A reorganizacao pode mover/copiar e apagar a origem de um arquivo fora do curso, criando tambem destino controlado pelo atacante.

fix: Aplicar autorizacao Main-only aos planos e mutacoes: validar curso ativo, sourceType, raiz canonica, origem, destino e frescor do preview. Bloquear exclusao fisica de local-ref sem fluxo explicito e seguro.

acceptance checklist:

- [] Mutacao fabricada pelo renderer e recusada.
- [] Origem e destino precisam estar dentro da raiz autorizada.
- [] delete-lesson nao apaga arquivos local-ref por padrao.
- [] Testes cobrem ID valido com caminho externo e plano com destino fora do curso.

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

title: [Seguranca] Bloqueia atalhos e caminhos arbitrarios em system:open-path

labels: security, severity:medium

problem: A allowlist de extensoes e usada como unica barreira antes de shell.openPath. Ela inclui .lnk, .url, .html, .htm e .webloc; no Windows, abrir um .lnk pelo shell pode executar o alvo do atalho.

exploitability: Requer acesso ao bridge por renderer comprometido e a existencia de um arquivo com uma extensao aceita. Um .lnk pode apontar para um comando local; .url pode abrir uma URL e HTML pode executar conteudo no navegador padrao.

evidence:

- src/main/ipc/settings.ipc.ts:74-82: open-path valida string, extensao e isFile, e entao chama shell.openPath(filePath).
- src/main/utils/file-utils.ts:88-95: LINK_EXTENSIONS inclui .url, .lnk, .html, .htm e .webloc.
- src/main/utils/file-utils.ts:158-166: isImportableFile considera LINK_EXTENSIONS como permitido.
- src/preload/index.ts:396-400: openPath e exposto ao renderer como funcao que aceita path livre.

impact: O impacto varia de execucao de comando via atalho a phishing/navegacao externa. O risco nao e eliminado pelo teste de stat.isFile().

fix: Trocar a allowlist por capability/caminho registrado e excluir .lnk, .url, .webloc e HTML da abertura pelo shell. Manter abertura externa exclusivamente por URL validada e fluxo explicito.

acceptance checklist:

- [] Um path livre nunca e passado a shell.openPath.
- [] .lnk, .url, .webloc e HTML sao recusados ou tratados em fluxo isolado.
- [] Ha teste de regressao para .lnk e para path fora do inventario.

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

title: [Seguranca] Elimina caminhos crus dos endpoints de importacao e leitura

labels: security, severity:high

problem: O fluxo novo usa capabilities e sessoes Main-owned, mas o fluxo multi-curso ainda escaneia folderPath livre e import-batch persiste proposal.rootPath, lesson.filePath e resource.filePath sem verificar que vieram do scan autorizado.

exploitability: Um renderer comprometido pode fabricar uma proposta apontando para um PDF, video ou recurso privado fora do curso selecionado e chamar import-batch. O mesmo limite aparece no plano de organizacao e no conversor SRT, que aceitam caminhos crus.

evidence:

- src/main/ipc/courses.ipc.ts:671-685: scan-multi-course-folder aceita folderPath cru e escaneia o diretorio recebido.
- src/main/ipc/courses.ipc.ts:695-719: import-batch valida apenas items nao vazio e passa proposal diretamente a buildCourseHierarchy/saveCourseWithHierarchy.
- src/main/services/course-import.service.ts:622-655,685-728: buildCourseHierarchy copia rootPath, lesson.filePath, coverPath e resource.filePath para entidades persistentes.
- src/main/services/database.service.ts:126-147: getRegisteredMediaPaths agrega os caminhos persistentes em courses, lessons e content_resources.
- src/main/protocol.ts:162-186,295-317: O media:// authorizer permite caminho registrado exatamente e o handler faz o streaming apos a autorizacao.
- src/renderer/src/components/import/ImportWizard.tsx:322-366,459-485: O fluxo de multiplos cursos ainda chama scan cru e depois importBatch.
- src/main/ipc/courses.ipc.ts:863-877: convert-srt-to-vtt tambem le e retorna conteudo de um srtPath cru apos apenas validar extensao/existencia.
- src/main/services/organization/organization-plan.service.ts:198-234: applyPlan aceita details.newFilePath do plano recebido e grava file_path sem revalidar escopo.

impact: Os caminhos persistentes entram em getRegisteredMediaPaths. O protocolo media:// entao os trata como registrados e permite leitura/streaming do arquivo pela aplicacao, transformando uma entrada controlada pelo renderer em autorizacao persistente.

fix: Desativar import-batch/scan legado ou adaptar ambos ao registry de capability e a uma sessao Main-owned. Validar todos os caminhos no Main antes de persistir ou ler e cobrir import, plano, SRT e content_resources.

acceptance checklist:

- [] Proposta fabricada com filePath fora do sourceRoot e recusada.
- [] Somente caminhos emitidos pelo Main entram no banco.
- [] media:// continua negando arquivo nao registrado.
- [] SRT e plano de organizacao recusam caminhos crus.

--- FIM ISSUE 5 ---